

Enterprise Cybersecurity Risk Management Report

Business Supplies, Inc. (BSI)

Cybersecurity Risk Management Case Study

Executive Summary

This project presents a comprehensive Cybersecurity Risk Management Program for Business Supplies, Inc. (BSI), a regional logistics organization transitioning into a digital-first enterprise.

The objective was to transform an informal, reactive security posture into a structured and sustainable Governance, Risk, and Compliance (GRC) operating model aligned with international best practices.

The Problem: Growth Outpacing Governance

BSI's operational growth and digital expansion have exceeded the maturity of its cybersecurity governance framework. Key challenges identified include:

- **Reactive Security Posture:** No dedicated security personnel and no formal Information Security Policy (ISP).
- **Infrastructure Technical Debt:** Critical identity and financial systems operating on aging, end-of-life hardware.
- **Compliance Exposure:** Absence of formal audit validation for PCI and employee-sensitive data (including medical-related records).

Collectively, these conditions elevate the organization's exposure to financial disruption, regulatory penalties, and reputational damage.

The Solution: ISO/IEC 27001 Implementation

To address these gaps, the ISO/IEC 27001 framework was selected to establish a formal Information Security Management System (ISMS).

This framework was chosen for its:

- **Risk-Based Governance Model:** Ensuring investment is directed toward high-impact risk areas.
- **Executive Accountability Structure:** Formal risk ownership and required management review cycles.
- **Competitive Differentiation:** Potential for auditable certification supporting high-value contract acquisition.

The implementation aligns cybersecurity operations with enterprise-level governance expectations.

Key Analytical Artifacts

1. Weighted Asset Risk Assessment

A quantitative weighted scoring model was developed to evaluate 23 technical assets and consolidate them into 8 executive-level business bundles.

Primary weighting factors:

- Revenue Impact (45%)
- Legal / Regulatory Liability (35%)

Top-ranked asset: **TERP-Web (E-commerce Platform)** due to its combined PCI exposure and direct revenue dependency.

2. Threat Landscape Analysis

Threat vectors were ranked using Likelihood and Current Vulnerability criteria.

Primary enterprise risks identified:

- Information Extortion (Ransomware)
- Human Error (Phishing / Social Engineering)

3. Risk Heat Map (Likelihood $\times$ Impact)

A quantitative risk matrix identified multiple “Red Zone” critical exposures (Score = 25), including:

- Human Error × Banking Data
- Obsolescence × Identity Infrastructure (AD SQL DB)

These intersections represent business-disrupting risk concentrations requiring immediate mitigation.

12-Month Mitigation Roadmap

A phased remediation plan was developed to reduce critical exposure and establish governance sustainability:

- **Q1:** Launch Security Awareness Training to reduce high-frequency human risk factors.
- **Q2:** Replace legacy server infrastructure to eliminate predictable obsolescence vulnerabilities.
- **Q3:** Modernize and encrypt enterprise backup systems (BARS) to improve ransomware resilience.

Collectively, these initiatives are projected to reduce red-zone risk exposure by more than 40% within the first year of implementation.

1 Organizational Context

BSI operates logistics, fleet management, payroll systems, and an online commerce platform. Digital systems now directly drive revenue generation, regulatory exposure, and operational continuity.

Current gaps include:

- No formal Information Security Policy
- No structured risk register
- Aging infrastructure (Server A and B)
- Limited compliance validation (PCI, PII)
- No recurring executive security review

Security maturity remains informal and reactive.

2 Selected Framework: ISO/IEC 27001

ISO/IEC 27001 was selected due to its:

- Risk-based Information Security Management System (ISMS)
- Executive accountability requirements
- Defined risk ownership
- Management review mandates
- Certification capability for competitive positioning

Unlike purely technical frameworks, ISO 27001 embeds governance into business operations.

3 Risk Assessment Methodology

The risk assessment followed a structured lifecycle:

1. Asset Identification and Bundling
2. Asset Classification and Ownership Assignment

3. Threat Identification
4. Weighted Asset Prioritization
5. Likelihood $\times$ Impact Risk Scoring
6. Risk Treatment Planning

Risk Score = Likelihood $\times$ Impact (1–5 scale). Red Zone = 21–25 (Critical).

4 Information Asset Identification

#	Asset Bundle	Owner	Classification	Data Types
A1	TERP-Web	Sales/IT	Restricted	PCI, Customer Data
A2	TAS-Bank Data	CFO	Highly Confidential	Bank Credentials
A3	TAS-GL Ledger	CFO	Confidential	Financial Records
A4	TAS-Pay (PII)	HR	Restricted	PII, Medical Data
A5	AD SQL DB	IT Manager	Highly Confidential	Credentials
A6	Fleet Logistics	Distribution	Confidential	GPS, Logs
A7	Client CRM	Sales	Confidential	Sales Data
A8	Enterprise Backups	IT	Confidential	All Systems Data

Table 1: Table 1 – Information Asset Bundles

5 Weighted Asset Ranking

Asset	C1	C2	C3	C4	Weighted Total
TERP-Web	5	5	4	4	4.80
TAS-Bank Data	5	5	3	4	4.70
TAS-GL	5	4	3	5	4.45
TAS-Pay	3	5	3	4	3.80
AD SQL DB	4	2	4	5	3.40
Fleet Logistics	4	1	3	4	2.85
Client CRM	3	2	2	3	2.55
Enterprise Backups	1	1	5	5	1.80

Table 2: Table 2 – Weighted Asset Ranking

Criteria Weights:

- C1: Revenue Impact (0.45)

- C2: Legal/Regulatory Liability (0.35)
- C3: Cost of Protection (0.10)
- C4: Recovery Complexity (0.10)

6 Threat Analysis

Threat	C1	C2	C3	C4	Weighted Total
Information Extortion	5	5	4	3	4.55
Software Attacks	4	5	4	4	4.30
Human Error	5	4	5	2	4.40
Tech HW Failure	3	4	4	2	3.45
Obsolescence	3	4	5	3	3.80

Table 3: Table 3 – Weighted Threat Ranking

Threat Ranking Criteria:

- C1: Likelihood (0.35)
- C2: Economic Impact (0.30)
- C3: Current Vulnerability (0.25)
- C4: Detection Difficulty (0.10)

7 Risk Matrix (Likelihood $\times$ Impact)

Asset	Extortion	Software	Human Error	Obsolete	HW Fail
TAS-Bank	20	15	25	15	8
TERP-Web	20	25	25	25	8
TAS-GL	25	8	16	16	15
TAS-Pay	16	20	20	12	9
AD SQL DB	25	9	12	25	15

Table 4: Table 4 – Risk Matrix (Red = 21–25 Critical)

Critical intersections are concentrated in:

- Human Error $\times$ Banking Data

- Software Attacks × TERP-Web
- Obsolescence × AD SQL DB

8 Governance Risk Ownership Model

To sustain risk reduction, BSI must implement:

- Defined Risk Owners (CFO, HR, IT Manager)
- Quarterly Risk Review Meetings
- Formal Risk Register Maintenance
- Executive Risk Dashboard Reporting
- Internal Audit Alignment

ISO 27001 Clause 9 (Performance Evaluation) requires measurable oversight.

9 12-Month Remediation Roadmap

Quarter 1:

- Security Awareness Training
- Information Security Policy Development

Quarter 2:

- Server A and B Replacement
- Patch Management Formalization

Quarter 3:

- Backup Modernization (Encrypted BARS)
- Disaster Recovery Testing

Quarter 4:

- Incident Response Plan
- Internal Compliance Audit

Estimated red-zone risk reduction: ~40%.

10 Control Alignment (ISO 27001)

Risk	ISO Control	Mitigation
Human Error	A.7.2.2	Security Training
Obsolescence	A.12.6.1	Patch Management
Backup Risk	A.12.3.1	Backup Policy
Access Risk	A.9.2	Access Control

Conclusion

BSI's current cybersecurity posture exposes the organization to critical operational and regulatory risk. By implementing an ISO/IEC 27001-aligned risk management program, BSI transitions from reactive IT management to enterprise-level risk governance.

This initiative protects revenue, reduces liability, and establishes long-term resilience.

Appendix A – Comprehensive Threat Inventory

Prior to consolidation into weighted threat categories (Table 3), a broad environmental threat inventory was conducted. This step ensures completeness of risk identification before prioritization.

The following table represents specific threat scenarios relevant to BSI’s operating model. These were later grouped into strategic threat classes for executive reporting.

#	Threat (Specific Example for BSI)	Threat Classification
1	Ransomware on TAS-GL/Pay	Information Extortion
2	Phishing targeting employees	Human Error / Social Engineering
3	SQL Injection on TERP-Web	Software Attacks
4	Server/NAS Disk Failure	Technical Hardware Failure
5	Unpatched ERP Software Bugs	Technical Software Failure
6	Competitor stealing client lists	Espionage / Trespass
7	Flooding in Room 127	Forces of Nature
8	Using obsolete Windows systems	Technological Obsolescence
9	Theft of delivery truck laptops	Theft
10	ISP Outage	Deviation in Quality of Service
11	Disgruntled technician damaging racks	Sabotage / Vandalism
12	Patent infringement of software	Intellectual Property Compromise

Table 5: Detailed Threat Inventory Prior to Consolidation

Professional Note: This inventory demonstrates breadth of environmental scanning across technical, human, environmental, operational, and strategic threat vectors. For executive clarity, these were consolidated into five weighted threat categories in the main report.

Appendix B – Detailed Asset Scoring Model (Pre-Bundling)

Prior to consolidating assets into business-aligned bundles (Table 1), each of the 23 individual information assets was independently evaluated using a four-factor weighted model.

This approach reflects enterprise risk modeling practices commonly used in advisory and audit engagements.

Scoring Criteria (Enterprise Model)

- C1: Revenue Impact (0.35)
- C2: Legal / Regulatory Exposure (0.30)
- C3: Reputational Impact (0.20)
- C4: Operational Continuity Impact (0.15)

Model Evolution Note: The initial executive model weighted Revenue (45%) and Legal Exposure (35%) more heavily to reflect immediate financial sensitivity. However, during analysis refinement, the model was expanded to include Reputational and Continuity dimensions.

This shift reflects a more mature enterprise risk perspective consistent with Big 4 advisory methodologies, where long-term reputational damage and operational resilience are considered material risk drivers alongside direct revenue impact.

#	Information Asset	C1	C2	C3	C4	Total
1	AD Service	4	2	2	4	3.00
2	AD SQL DB	4	3	3	5	3.65
3	DNS Service	3	1	1	3	2.00
4	DNS SQL DB	3	1	2	4	2.35
5	TAS-GL (Ledger)	5	3	5	5	4.40
6	TAS-AP	3	2	3	4	2.85
7	TAS-Pay (Payroll)	3	5	4	4	4.00
8	TERP-Web DB	5	5	5	3	4.70
9	Opt-HR Medical Records	1	5	5	3	3.30
10	TAS-Bank Data	5	5	5	4	4.85
11	TAS-AR	4	1	3	4	2.90
12	TERP-CRM	3	2	4	3	2.90

13	TDA-Inventory	4	1	2	3	2.55
14	Opt-Time Records	2	3	2	3	2.45
15	TDA-PO History	2	1	1	2	1.50
16	TDA-SO History	2	1	1	3	1.65
17	Email / Exchange DB	2	1	2	3	1.85
18	TDA-Warehouse Logic	2	1	1	4	1.65
19	TAS-Fixed Assets	1	1	1	2	1.15
20	HR Performance Reviews	1	4	4	2	2.65
21	Marketing / Strategic Plans	1	1	5	4	2.25
22	BARS Backup Data Sets	1	1	2	5	1.80
23	Network Configuration Files	1	1	1	4	1.45

Table 6: Detailed 23-Asset Weighted Scoring Model

Rationale for Asset Bundling

Following quantitative scoring, assets were grouped into eight strategic bundles to:

- Improve executive readability
- Align risk reporting to business capabilities
- Reduce reporting complexity
- Support governance-level decision making

This bundling methodology reflects standard enterprise risk aggregation practices used in advisory and internal audit engagements.